NEXT ENGINEER · _SHEERAT_

Cyber Security

BCC401

One-day revision notes: definitions, solved examples, code and important questions

Program: B.Tech | **Branches:** CSE, IT, CSE-AIML, CSE-DS, AIDS | **Semester:** 4 | **Credits:** 2

L-T-P: 2-0-0

Scheme: AKTU B.Tech 2nd year, 2023-24 onwards (same syllabus as BCC301 in semester 3)

UNIT 1 Introduction to Cyber Crime

UNIT 2 Cyber Crime with Mobile and Wireless Devices

UNIT 3 Tools and Methods Used in Cyber Crime

UNIT 4 Understanding Computer Forensics

UNIT 5 Security Policies and Cyber Laws

Original revision notes written for the AKTU syllabus. This is a theory subject, so every unit has:

1. **2-mark definitions**: short answers you can write word for word in Section A.
2. **Core concepts**: classifications, steps and comparison tables that make up long answers.
3. **Solved examples**: short case studies showing how to apply the concepts.
4. **Key points to remember**: lists that are easy to reproduce.
5. **Important questions**: the long questions to prepare, with what your answer must contain.

How to use these notes the day before the paper

- **Morning (2 hours):** Units 1 and 2. Learn the classification of cybercrimes and the attack-planning phases; they appear in almost every paper.
- **Afternoon (2 hours):** Unit 3 is the largest. Learn one definition, how it works, and one defence for every tool/attack.
- **Evening (2 hours):** Units 4 and 5 (forensics life cycle, chain of custody, IT Act sections, DPDP Act 2023, IPR), then the "Last-hour checklist".
- **In the exam:** for every attack write *definition → how it works (with a small diagram/flow) → example → prevention*. Quote IT Act section numbers where relevant.

AKTU paper pattern (theory, 70 marks, 3 hours): Section A has 7 short questions of 2 marks, all compulsory (14). Section B has 5 questions of 7 marks, attempt any 3 (21). Section C has 5 questions (one per unit), each with two parts, attempt one part of each, 7 marks each (35). Every unit gets its own Section C question, so do not skip any unit.

UNIT 1 Introduction to Cyber Crime

✍️ 2-mark definitions

- **Cybercrime:** any illegal act in which a computer or network is the tool, the target, or both. The term "cyber" comes from cybernetics (William Gibson's "cyberspace", 1984).
- **Cyberspace:** the virtual world of interconnected computers, networks and data where online communication happens.
- **Cyber security:** protecting information, devices and networks from unauthorized access, use, disclosure, disruption, modification or destruction.
- **Information security (CIA triad): Confidentiality** (only authorized people see data), **Integrity** (data is not altered improperly), **Availability** (data and systems are usable when needed).
- **Cybercriminal:** a person who commits crimes using computers: hungry for recognition (hobby hackers, politically motivated hacktivists), not interested in recognition (insiders, psychological perverts, financially motivated), and insiders (disgruntled or former employees).
- **Social engineering:** manipulating people into giving out confidential information or performing actions, by exploiting trust rather than technical flaws.
- **Cyberstalking:** using the internet, email or other electronic means to repeatedly harass, threaten or follow someone.
- **Botnet:** a network of compromised computers ("bots"/"zombies") controlled remotely by an attacker (bot-herder) through a command-and-control server.
- **Attack vector:** the path or means by which an attacker reaches a target system (email attachments, malicious links, pop-ups, chat, removable media, unpatched software).

💡 Core concepts

Classification of cybercrimes

Against	Examples
Individuals	Email spoofing, spamming, cyber defamation, cyberstalking, password sniffing, identity theft, online frauds
Property	Credit card fraud, intellectual property crimes (software piracy, copyright infringement), internet time theft
Organizations	Unauthorized access/hacking, denial of service, virus/worm attacks, email bombing, salami attack, logic bomb, Trojan horse, data diddling, industrial espionage
Society	Forgery, cyber terrorism, web jacking, pornography

Quick meanings: **salami attack** (stealing tiny amounts many times), **data diddling** (altering data before or during input), **logic bomb** (code that triggers on a condition/date), **web jacking** (taking control of a website), **email bombing** (flooding a mailbox).

How criminals plan attacks (three phases)

1. **Reconnaissance (information gathering):** *passive* (search engines, social media, WHOIS, company websites; no contact with target) and *active* (probing the network, ping sweeps).
2. **Scanning and scrutinizing:** port scanning, network scanning, vulnerability scanning to find live systems, open ports, services and weaknesses.
3. **Launching the attack:** crack passwords, exploit weaknesses, gain and escalate privileges, run malicious commands, hide files, **cover tracks** (delete logs).

Social engineering types

Human-based	Computer-based
Impersonating an employee or valid user	Fake emails (phishing)
Posing as an important user (VIP)	Malicious email attachments
Using a third person ("the manager sent me")	Fake websites and pop-up windows
Calling technical support	Fake software/updates
Shoulder surfing	
Dumpster diving (searching trash)	

Cyberstalking: *online stalkers* use email, chat, social media; *offline stalkers* use online information to follow the victim physically. Steps: collect victim's personal information → establish contact → harass/threaten → may escalate to offline. Prevention: limit personal info online, keep evidence, report to cyber cell.

Cybercafés and cybercrime: shared computers may have keyloggers or saved passwords; users should never save passwords, should log out, clear history and avoid online banking there.

Botnets as fuel for cybercrime: botnets send spam, launch DDoS attacks, steal data, host phishing sites, click-fraud and spread malware. Protection: updated antivirus and OS, firewall, avoid unknown links and attachments.

Global perspective: cybercrime crosses borders, so cooperation matters (e.g. the Council of Europe **Budapest Convention on Cybercrime, 2001**). Laws, jurisdiction and evidence rules differ between countries.

Guidance for internet users (cybercrime era): strong unique passwords, 2-factor authentication, updated software, don't click unknown links, check HTTPS, back up data, be careful on public Wi-Fi.

🧮 Solved examples

Example 1 (classify the crime).

- An employee changes salary records before they are entered into payroll → **data diddling** (against organization).
- A fake email that looks like it is from the bank asks for a password → **phishing / email spoofing** (against individual).
- A programmer rounds off fractions of a rupee from many accounts into his own → **salami attack**.

Example 2 (attack planning in practice). An attacker searches LinkedIn for a company's IT staff (passive reconnaissance), runs a port scan on the company's IP range (scanning), finds an outdated

web server, exploits it, creates an admin account and deletes logs (launching attack and covering tracks).

Key points to remember

```
CIA triad: Confidentiality, Integrity, Availability
Crime classes: individual, property, organization, society
Attack phases: reconnaissance (passive/active) → scanning → launch (gain access, escalate, cover tracks)
Social engineering: human-based vs computer-based
Botnet = bots + command-and-control; used for spam, DDoS, data theft
```

⭐ Important questions

1. Define cybercrime and explain its classification with examples. *Use the four-way table.*
2. Who are cybercriminals? Explain their categories.
3. How do criminals plan attacks? Explain passive and active reconnaissance, scanning and attack. *Draw the phase flow.*
4. What is social engineering? Explain its types with examples and prevention.
5. Explain cyberstalking and botnets. How do botnets fuel cybercrime?
6. Write short notes on attack vectors and cybercafé-related crime.

NEXT ENGINEER _sheerat_

UNIT 2 Cyber Crime with Mobile and Wireless Devices

✍️ 2-mark definitions

- **Mobile computing:** using portable devices (phones, tablets, laptops) to access data and services from anywhere over wireless networks.
- **Mishing:** mobile phishing: phishing carried out through mobile phones (calls or SMS).
- **Vishing:** voice phishing: tricking people over phone calls into giving personal or financial details.
- **Smishing:** SMS phishing: fraudulent text messages with links or numbers to call.
- **Bluetooth attacks: bluejacking** (sending unsolicited messages), **bluesnarfing** (stealing data like contacts), **bluebugging** (taking control of the phone), **car whisperer** (eavesdropping via car kits).
- **Mobile Device Management (MDM):** software that lets an organization enforce policies, encrypt, track and remotely wipe employees' mobile devices.
- **BYOD:** "bring your own device": employees using personal devices for work, which creates security risks.
- **LDAP:** Lightweight Directory Access Protocol, used for directory-based authentication of users and devices.
- **RAS:** remote access server: lets mobile users connect to an organization's network; must be secured against unauthorized access.

💡 Core concepts

Mobility trends: growth of smartphones, mobile banking/UPI, mobile apps, cloud sync, IoT and wearables, BYOD. More devices and data on the move mean more targets.

Credit card frauds in the mobile era

- **Online:** stolen card details used for online purchases; fake shopping sites; phishing for card number and OTP.
- **Offline: skimming** (copying card data with a device at ATMs/shops), stealing the physical card, shoulder surfing PINs.
- Techniques: traditional (stolen/fake cards, application fraud, identity theft) and modern (triangulation fraud, credit card generators).
- Prevention: never share OTP/CVV, use virtual cards, enable transaction alerts, check for skimmers.

Security challenges posed by mobile devices: loss/theft of devices, malware in apps, insecure Wi-Fi, weak authentication, unpatched OS, data leakage through cloud backup, Bluetooth exploits.

Registry settings for mobile devices: on Windows-based devices, registry settings control security features (e.g. disabling auto-run, enforcing password policy, restricting installation). Misconfigured registry entries can be exploited, so organizations lock them down.

Authentication service security: secure the authentication path for mobile users, e.g. LDAP security, RAS security, strong passwords + 2FA, certificates, and protection against **cache poisoning** and **man-in-the-middle** attacks.

Attacks on mobile/cell phones: mobile phone theft, mobile viruses/malware, mishing, vishing, smishing, Bluetooth hacking, SIM swap fraud, malicious apps.

Organizational measures for handling mobile devices

- Written **mobile device security policy** (acceptable use, BYOD rules).
- **MDM**: enforce PIN/biometric, encryption, remote lock/wipe, app whitelisting.
- Disable unused interfaces (Bluetooth, infrared) and auto-connect Wi-Fi.
- VPN for remote access; regular patching; antivirus for mobiles.
- Employee awareness training; reporting lost devices immediately.
- Laptop security: cable locks, encryption, theft tracking software.

🧮 Solved examples

Example 1 (identify the attack).

- A text says "Your bank KYC expires today, click bit.ly/xyz" → **smishing**.
- A caller pretending to be from the bank asks for an OTP → **vishing**.
- Contacts are copied from a phone with Bluetooth left discoverable → **bluesnarfing**.

Example 2 (policy for a company issuing phones). Require a 6-digit PIN and encryption, enrol all phones in MDM, allow apps only from the official store, block USB debugging, enable remote wipe, and train staff to report loss within one hour.

Key points to remember

```
Mishing = mobile phishing → vishing (voice) + smishing (SMS)
Bluetooth: bluejacking (messages), bluesnarfing (steal data), bluebugging (control)
Card fraud: online (phishing, fake sites) vs offline (skimming, theft)
Org measures: policy, MDM, encryption, remote wipe, VPN, training
```

⭐ Important questions

1. Explain mobility trends and the security challenges posed by mobile devices.
2. Explain credit card frauds in the mobile and wireless era, with prevention.
3. Explain attacks on mobile phones: mishing, vishing, smishing and Bluetooth hacking.
4. Explain authentication service security (LDAP, RAS) and registry settings for mobile devices.
5. What organizational measures and security policies should be used for mobile devices? *Policy + technical + people measures.*

UNIT 3 Tools and Methods Used in Cyber Crime

✍️ 2-mark definitions

- **Proxy server:** a computer that sits between a user and the internet, forwarding requests; it can hide the user's IP, filter and cache content.
- **Anonymizer:** a tool or service that hides a user's identity online (e.g. anonymous proxies, Tor network).
- **Phishing:** tricking users into revealing sensitive information (passwords, card numbers) through fake emails or websites that look genuine.
- **Password cracking:** recovering passwords from stored or transmitted data. Types: **brute force**, **dictionary**, **hybrid**, **rainbow table**; **online** (against a live login) or **offline** (against stolen hashes).
- **Keylogger:** software or hardware that records keystrokes to capture passwords and messages.
- **Spyware:** software that secretly collects information about a user and sends it to someone else.
- **Virus:** malicious code that attaches to a host program and spreads when that program runs; needs human action to spread.
- **Worm:** self-replicating malware that spreads over networks on its own, without a host program.
- **Trojan horse:** malicious program disguised as useful software. **Backdoor:** a hidden way to bypass normal authentication.
- **Steganography:** hiding a secret message inside another file (image, audio, video) so its existence is not noticed.
- **DoS / DDoS:** making a service unavailable by overwhelming it with traffic, from one source (DoS) or many compromised machines (DDoS).
- **SQL injection:** inserting malicious SQL into input fields so the database runs unintended commands.
- **Buffer overflow:** writing more data into a buffer than it can hold, overwriting adjacent memory, which can crash a program or let an attacker run code.
- **Identity theft:** using someone else's personal information (name, Aadhaar, PAN, card details) to commit fraud.

💡 Core concepts

Virus vs worm vs Trojan

	Virus	Worm	Trojan
Needs host file	Yes	No	Disguised as a program
Self-replicates	Yes, when host runs	Yes, by itself	No
Spread	User action (sharing files)	Network, automatically	User installs it
Main harm	Corrupts files	Consumes bandwidth, spreads fast	Opens backdoor, steals data

Types of viruses: boot sector, program/file infector, multipartite, stealth, polymorphic, macro, active-X/Java, Trojan-dropper.

Password cracking methods

Method	How
Brute force	Tries every possible combination
Dictionary	Tries words from a word list
Hybrid	Dictionary words with numbers/symbols added
Rainbow table	Looks up precomputed hashes (defeated by salting)
Guessing/social	Uses personal info (birthdays, names)

Defence: long passphrases, salting + slow hashing (bcrypt), account lockout, 2FA.

Keyloggers: *software* (runs as hidden process, hooks keyboard API) and *hardware* (small device between keyboard and PC). Defence: anti-keylogger/antispyware, on-screen keyboards, 2FA, check USB ports.

Steganography vs cryptography

Steganography	Cryptography
Hides the existence of the message	Hides the meaning of the message
Cover file looks normal	Ciphertext looks like gibberish
Detected by **steganalysis**	Broken by **cryptanalysis**

Common method: LSB (least significant bit) insertion in image pixels.

DoS/DDoS attack types: bandwidth/flood attacks (UDP flood, ICMP/ping flood), **SYN flood** (half-open TCP connections), **ping of death** (oversized packets), **teardrop** (overlapping fragments), **smurf** (spoofed ICMP broadcast amplification), application-layer (HTTP flood). Defence: firewalls, rate limiting, traffic filtering, load balancing, CDN/DDoS protection services, intrusion prevention.

SQL injection

- Vulnerable code builds a query by joining strings: `"SELECT * FROM users WHERE name='" + user + "' AND pass='" + pwd + "'"`
- Entering `' OR '1'='1` makes the condition always true, logging in without a password.
- Types: in-band (error-based, union-based), blind (boolean/time-based), out-of-band.
- Defence: **parameterized queries / prepared statements**, input validation, stored procedures, least-privilege DB accounts, web application firewall.

Buffer overflow: stack-based (overwrites return address to jump to attacker code, often with a **NOP sled**) and heap-based. Defence: bounds checking, safe functions (`strncpy` instead of `strcpy`), stack canaries, ASLR, non-executable stack (DEP).

Attacks on wireless networks: war driving (searching for open Wi-Fi), MAC address spoofing, evil twin / rogue access point, eavesdropping, man-in-the-middle, WEP/WPA key cracking, de-authentication attacks. Defence: WPA3/WPA2-AES, strong passphrase, disable WPS, hide/rename default SSID, MAC filtering (weak alone), VPN.

Phishing techniques: deceptive email phishing, **spear phishing** (targeted at one person/group), **whaling** (targets top executives), clone phishing, pharming (redirecting DNS to fake sites), vishing/smishing, link manipulation, website forgery. Indicators: urgent tone, mismatched sender/URL, spelling errors, requests for credentials.

Identity theft types: financial, criminal (giving someone else's identity when arrested), identity cloning, medical, synthetic identity, child identity theft. Techniques: phishing, dumpster diving, skimming, data breaches, social media mining. Prevention: shred documents, monitor statements, never share OTP/Aadhaar casually, strong passwords.

🧮 Solved examples

Example 1 (SQL injection walk-through). A login form runs `SELECT * FROM users WHERE name='$u' AND pass='$p'`. The attacker types username `admin' --`. The query becomes `SELECT * FROM users WHERE name='admin' --' AND pass=''`; everything after `--` is a comment, so the password check disappears. **Fix:** use a prepared statement: `cursor.execute("SELECT * FROM users WHERE name=%s AND pass=%s", (u, p))`.

Example 2 (choose the right term).

- Malware that spread to millions of PCs through a network flaw with no user action → **worm**.
- A free "PDF converter" that secretly opens remote access → **Trojan with backdoor**.
- A secret message hidden in the colour bits of a holiday photo → **steganography**.

Key points to remember

```
Virus (needs host) vs Worm (self-spreads) vs Trojan (disguised)
Password attacks: brute force, dictionary, hybrid, rainbow table → defend with salt + 2FA
Keylogger: software / hardware
Stego hides existence, crypto hides meaning
DoS types: SYN flood, ping of death, teardrop, smurf; DDoS uses botnets
SQLi: ' OR '1'='1  → fix with prepared statements
Buffer overflow → canaries, ASLR, DEP, bounds checks
Phishing family: spear, whaling, pharming, vishing, smishing
```

⭐ Important questions

1. Explain proxy servers and anonymizers; how are they misused by criminals?
2. What is phishing? Explain its techniques and types, and how to prevent it. *Include spear phishing and whaling.*
3. Explain password cracking techniques and countermeasures.
4. Differentiate virus, worm and Trojan horse; explain keyloggers, spyware and backdoors.
5. What is steganography? Compare it with cryptography.
6. Explain DoS and DDoS attacks with types and protection.
7. Explain SQL injection and buffer overflow attacks with examples and prevention.
8. Explain attacks on wireless networks and identity theft.

UNIT 4 Understanding Computer Forensics

✍️ 2-mark definitions

- **Computer (digital) forensics:** applying investigation and analysis techniques to collect, preserve, examine and present digital evidence in a way that is legally acceptable.
- **Digital evidence:** information stored or transmitted in digital form that may be used in court (files, emails, logs, metadata, images of disks).
- **Cyber forensics:** forensics on computers, networks and other digital devices for investigating cybercrime.
- **Chain of custody:** the documented, unbroken record of who collected, handled, transferred and stored a piece of evidence, and when, to prove it was not tampered with.
- **Forensic image:** a bit-by-bit copy of a storage device, made with a write-blocker, on which analysis is done instead of the original.
- **Hashing (MD5/SHA):** computing a fingerprint of evidence so any later change can be detected; the hash of the image must match the original.
- **Network forensics:** capturing, recording and analysing network traffic and logs to find the source of an attack.
- **Email header analysis:** examining "Received", "From", "Return-Path", "Message-ID" and IP fields to trace the true origin of an email.

💡 Core concepts

Need for computer forensics: to investigate cybercrimes, recover deleted data, prove or disprove allegations, support court cases, handle insider misuse and policy violations, and respond to incidents.

Rules of digital evidence: it must be **admissible**, **authentic**, **complete**, **reliable** and **believable**. Under Indian law, electronic records are admissible under the Indian Evidence Act (Section 65B certificate), now carried into the Bharatiya Sakshya Adhiniyam, 2023.

Digital forensics life cycle

1. **Preparation and identification:** plan, get authorization, identify devices and sources of evidence.
2. **Collection / acquisition:** seize devices; create forensic images using write-blockers; photograph the scene.
3. **Preservation:** compute hashes, store securely, maintain chain of custody.
4. **Examination and analysis:** recover deleted files, search keywords, build timelines, analyse logs, emails, registry.
5. **Reporting / presentation:** document findings clearly so they can be presented and defended in court.

(Some books list it as: preparation → collection → examination → analysis → reporting → testifying.)

Chain of custody record contains: evidence description, who collected it, date/time/place, every transfer (from whom, to whom, when, why), storage location, and signatures. A broken chain can make evidence inadmissible.

Forensic analysis of email: examine headers to trace IPs and mail servers, check timestamps, verify sender domain (SPF/DKIM/DMARC), recover deleted emails, check attachments for malware. Spoofed emails are identified when the "From" address does not match the originating server.

Approaching a computer forensics investigation: secure the scene → document everything → decide live vs dead acquisition (capture RAM first if the system is on: **order of volatility** — registers/cache, RAM, network state, running processes, disk, backups) → image → hash → analyse on the copy → report.

Network forensics: sources are firewall/IDS logs, router logs, packet captures (Wireshark/tcpdump), NetFlow data. Used to trace intrusions, DDoS sources and data exfiltration.

Forensics and social networking sites: posts, messages, photos (with metadata/geotags) and friend links are evidence. Threats: privacy leaks, fake profiles, cyberbullying, identity theft. Challenges: data on foreign servers, need for provider cooperation, deleted/ephemeral content.

Challenges in computer forensics: encryption, anti-forensics (wiping, steganography, log deletion), huge data volumes, cloud and cross-border data, many device types (IoT, mobiles), fast-changing technology, legal admissibility and privacy issues.

Common tools: EnCase, FTK (Forensic Toolkit), Autopsy/Sleuth Kit, Wireshark, Volatility (memory), write-blockers.

🧮 Solved examples

Example 1 (chain of custody entry).

Item	Collected by	Date/time	Transferred to	Purpose	Hash (SHA-256)
1 TB laptop HDD (S/N X123)	Insp. A. Kumar	12-03 10:15	Forensic lab (R. Singh)	Imaging	9f2c… (matches image)

Example 2 (spoofed email). An email claims to come from `hr@company.com`, but its "Received: from" line shows an unrelated foreign IP and the SPF check fails. Conclusion: the sender address is **spoofed**; the originating IP is the lead to follow.

Key points to remember

```
Life cycle: identify → collect (image, write-blocker) → preserve (hash, custody) → analyse → report
Evidence must be: admissible, authentic, complete, reliable, believable
Chain of custody = who, what, when, where, why for every handling
Order of volatility: registers/cache → RAM → network/processes → disk → backups
Challenges: encryption, anti-forensics, volume, cloud, jurisdiction
```

⭐ Important questions

1. What is computer forensics? Explain the need for it and the types of digital evidence.
2. Explain the digital forensics life cycle with a diagram.
3. What is chain of custody? Why is it important? *Give the fields of a custody record.*

4. Explain forensic analysis of email and network forensics.
5. How should a computer forensics investigation be approached? Discuss the challenges in computer forensics.
6. Discuss forensics and social networking sites: security and privacy threats.

NEXT ENGINEER
sheerat

UNIT 5 Security Policies and Cyber Laws

✍️ 2-mark definitions

- **Information security policy:** a formal document approved by management that states how an organization protects its information assets, and the rules everyone must follow.
- **Cyber law:** the legal framework dealing with the internet, computers and electronic records: crimes, e-commerce, digital signatures, data protection.
- **IT Act, 2000:** India's main cyber law, giving legal recognition to electronic records and digital signatures and defining cyber offences; amended in **2008**.
- **Digital Personal Data Protection (DPDP) Act, 2023:** India's law on processing digital personal data, balancing individuals' rights with lawful processing.
- **Data Principal:** the individual the personal data belongs to (for a child, includes the parent/guardian).
- **Data Fiduciary:** the entity that decides why and how personal data is processed. **Data Processor:** processes data on behalf of a fiduciary.
- **Intellectual property (IP):** creations of the mind (inventions, works, brands, designs) protected by law.
- **Patent:** an exclusive right for an invention that is new, inventive and industrially applicable, for **20 years**.
- **Copyright:** protection for original literary, artistic, musical works and software; generally the author's **life + 60 years** in India.
- **Trademark:** a sign, logo, name or symbol that distinguishes goods/services; registered for **10 years**, renewable indefinitely.

💡 Core concepts

Need for an information security policy: sets rules and responsibilities, protects confidentiality, integrity and availability, ensures legal compliance, guides incident response, builds awareness, and gives a basis for disciplinary action. **Typical policies:** acceptable use, password, email, remote access/VPN, BYOD/mobile, backup, incident response, access control, data classification. **Policy life cycle:** risk assessment → draft → management approval → communicate and train → implement → monitor → review and update.

IT Act 2000 (as amended in 2008): important sections

Section	Offence / provision
43	Unauthorized access, downloading, virus introduction, damage to computer systems: compensation to the victim
43A	Body corporate failing to protect sensitive personal data: compensation
65	Tampering with computer source documents
66	Computer-related offences (dishonest/fraudulent acts under Sec 43)

Section	Offence / provision
66B	Dishonestly receiving a stolen computer resource
66C	Identity theft (misusing passwords, digital signatures)
66D	Cheating by personation using computer resources
66E	Violation of privacy (capturing/publishing private images)
66F	Cyber terrorism (punishable up to life imprisonment)
67, 67A, 67B	Publishing obscene, sexually explicit, and child sexual abuse material
69, 69A	Government powers to intercept/decrypt information and to block websites
72	Breach of confidentiality and privacy
79	Safe harbour (exemption) for intermediaries that follow due diligence

Section 66A (offensive messages) was **struck down** by the Supreme Court in *Shreya Singhal v. Union of India* (2015).

DPDP Act, 2023: objectives and scope

- **Objective:** let personal data be processed for lawful purposes while protecting individuals' right to protect their data.
- **Scope:** digital personal data processed in India (collected digitally, or collected offline and digitized), and processing outside India if it is for offering goods or services to people in India. It does not cover personal data processed for purely personal/domestic purposes or data made public by the individual.
- **Key principles:** consent (free, specific, informed, unambiguous, withdrawable), purpose limitation, data minimisation, accuracy, storage limitation, security safeguards, accountability.
- **Rights of the Data Principal:** information about processing, correction and erasure, grievance redressal, and nominating someone to act on their behalf.
- **Duties of the Data Principal:** not to impersonate, not to suppress information, not to file false complaints.
- **Obligations of Data Fiduciaries:** take valid consent with notice, protect data, notify breaches to the Board and affected people, erase data when the purpose is over, appoint a grievance officer. **Significant Data Fiduciaries** have extra duties (Data Protection Officer, audits, impact assessments).
- **Children's data:** needs verifiable parental consent; no tracking, behavioural monitoring or targeted advertising directed at children.
- **Consent Managers** help individuals manage consent. The **Data Protection Board of India** enforces the Act; penalties go up to **₹250 crore** per breach.

Intellectual property in India

IP type	Law	Protects	Term
Patent	Patents Act, 1970	Inventions	20 years
Copyright	Copyright Act, 1957	Literary, artistic, musical works, software, films	Life of author + 60 years (generally)

IP type	Law	Protects	Term
Trademark	Trade Marks Act, 1999	Brand names, logos	10 years, renewable
Industrial design	Designs Act, 2000	Shape/look of products	10 + 5 years
Geographical indication	GI Act, 1999	Products tied to a place (e.g. Darjeeling tea)	10 years, renewable

IP issues in cyberspace: software piracy, copyright infringement by downloading/sharing, **cybersquatting** (registering domain names of known brands), linking and framing, plagiarism, trademark misuse in metatags.

🧮 Solved examples

Example 1 (apply the IT Act).

- Someone logs into a friend's email using a stolen password and sends messages as them → **Sec 66C (identity theft)** and **66D (cheating by personation)**.
- A company leaks customers' health data due to poor security → **Sec 43A** compensation (and DPDP Act penalties).
- Publishing someone's private photos without consent → **Sec 66E**.

Example 2 (DPDP Act roles). A food-delivery app collects your name, phone and address. You are the **Data Principal**, the app company is the **Data Fiduciary**, and its cloud provider is a **Data Processor**. If the app suffers a breach, it must inform the Data Protection Board and you.

Key points to remember

```
IT Act 2000, amended 2008;  66A struck down (2015)
43 compensation, 65 source code tampering, 66 hacking, 66C identity theft, 66D personation,
66E privacy, 66F cyber terrorism, 67 obscenity, 72 confidentiality, 79 intermediaries
DPDP Act 2023: Principal, Fiduciary, Processor, Consent Manager, Data Protection Board; up to ₹250
crore
Patent 20 yrs;  copyright life + 60;  trademark 10 yrs renewable
```

⭐ Important questions

1. Why does an organization need an information security policy? Explain the types of security policies.
2. Explain the IT Act 2000 and its 2008 amendment, with important sections and penalties.
3. Explain the objectives and scope of the Digital Personal Data Protection Act, 2023, with rights and duties.
4. What are intellectual property rights? Explain patents, copyright and trademarks in India.
5. Discuss intellectual property issues in cyberspace (piracy, cybersquatting, linking).

Last-hour checklist

Read only this in the last hour before the paper.

- ☐ Definition of cybercrime; CIA triad.
- ☐ Four-way classification of cybercrime with examples.
- ☐ Attack phases: reconnaissance → scanning → launch.
- ☐ Social engineering: human-based vs computer-based.
- ☐ Mishing, vishing, smishing; Bluetooth attacks.
- ☐ Mobile security measures: policy, MDM, encryption, remote wipe.
- ☐ Virus vs worm vs Trojan table.
- ☐ Password cracking types; keyloggers; steganography vs cryptography.
- ☐ DoS types; SQL injection example and fix; buffer overflow defences.
- ☐ Forensics life cycle; chain of custody; order of volatility.
- ☐ IT Act key sections; 66A struck down.
- ☐ DPDP Act 2023 roles, rights, penalties.
- ☐ Patent / copyright / trademark terms.

Books prescribed by AKTU

These are the books named in the AKTU syllabus. Buy or borrow them through a bookshop or your college library. The WorldCat links show which libraries hold a copy.

#	Title	Author(s)	Publisher	Where to get it legally
1	Cyber Security: Understanding Cyber Crimes, Computer Forensics and Legal Perspectives	Nina Godbole, Sunit Belapure	Wiley India	WorldCat
2	Cyber Security and Cyber Laws	Alfred Basta, Nadine Basta, Mary Brown, Ravinder Kumar	Cengage Learning	WorldCat
3	Introduction to Information Security and Cyber Laws	Surya Prakash Tripathi, Ritendra Goyal, Praveen Kumar Shukla	Dreamtech Press	WorldCat
4	Cyber Security and Data Privacy	Krishan Kumar Goyal, Amit Garg, Saurabh Singhal	—	WorldCat
5	Cybersecurity: Managing Systems, Conducting Testing, and Investigating Intrusions	Thomas J. Mowbray	John Wiley & Sons	WorldCat
6	Cyber Security Essentials	James Graham, Ryan Olson, Rick Howard	CRC Press	WorldCat
7	Anti-Hacker Tool Kit	Mike Shema	McGraw-Hill	WorldCat

The full text of the IT Act and the DPDP Act, 2023 is free on the official India Code and MeitY websites.

Official syllabus: AKTU B.Tech 2nd year CSE syllabus, 2023-24 scheme (PDF)

NEXT ENGINEER
sheerat